MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 031 · SEPTEMBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

EXPLAINER · CUI BASICS

What Actually Makes a File CUI

CUI is a government designation, not a judgment you make on a file's contents. How marking, derivative marking, and decontrol actually work.

BY **MAXINE** READING TIME · 6 MIN CUI · CUI-REGISTRY · MARKING · DFARS · SCOPING

file does not become Controlled Unclassified Information because it looks sensitive, because your engineers drew it, or because you would rather a competitor never saw it. Most program managers who are new to a CUI-bearing contract get this backwards on day one, and the confident ones get it backwards in the expensive direction: they start deciding, drawing by drawing, which of their own files feel important enough to protect. That is not how the designation works, and the mechanics of how it actually works answer most of the questions that come up in the first ninety days of a program.

Who decided this is CUI - us or the government?

The government did, and the channel it uses is narrower than most people assume. CUI is not a sensitivity label you apply to your own material because it seems worth protecting. It is a designation made upstream of you, and it reaches your desk through the contract: the clause that invokes it, the DD Form 254 if the contract carries one, and the markings already stamped on anything handed to you. The categories themselves - Controlled Technical Information, Export Control, Privacy, dozens of others - are defined once, government-wide, in the CUI Registry that the National Archives and Records Administration maintains. Nobody at your company gets to add a category, and nobody gets to decide a file qualifies because it looks important. If the paperwork does not say so, your read on how sensitive a drawing looks is not the test.

CUI is a designation the government makes, not a judgment you make.

So what actually triggers the marking on one of our files?

Three doors cover almost every real case. The file arrived already marked, from a prime or a government office, and the marking is the instruction - full stop. The file was created by your company under a contract whose terms designate a category for exactly this kind of work product, which means the obligation exists whether or not anyone remembered to stamp a header. Or the file is derivative: built from, excerpted from, or substantially informed by something that was CUI, which makes it CUI too, marked or not.

That third door is where small shops actually get into trouble, and they get into trouble going both directions. A drawing package that incorporates a CUI-marked spec inherits the designation even if nobody re-stamped the derived file. An internal memo that merely discusses a program, without reproducing controlled content, does not automatically inherit anything just because the program is sensitive. Derivative marking asks a specific question - does this file actually carry the controlled material forward, or does it just live near it - and shops that skip asking it tend to answer wrong in whichever direction is easier that afternoon.

Isn't it just safer to mark everything CUI and move on?

It feels safer and it is the more expensive mistake of the two, so it earns the most space here. The moment you decide "when in doubt, mark it," you have not made a marking decision. You have made a scoping decision, and you have made it against yourself: every system that can touch a CUI-marked file is now inside your assessment boundary, and that boundary is what drives the cost of your whole compliance program. We priced exactly that decision in Enclave or Whole Network? The Scoping Decision, Priced - the short version is that 110 controls applied to a purpose-built enclave is a different project, and a different bill, than the same 110 controls applied to your entire file server because a shared drive got the blanket-CUI treatment. Over-marking is not caution. It is a recurring invoice you wrote for yourself, and it does not even buy the safety it promises, because a workforce marking everything CUI stops reading markings at all. A properly scoped CUI enclave only works if the boundary reflects what is actually designated - build it around a marking error and you have just paid to enclose the wrong set of files.

What's the actual risk if we mark too little instead?

Different shape of exposure, and it lands on a person rather than on a budget line. Under-marked material that should have carried a designation is CUI sitting unprotected, which is a control failure in its own right - and if your organization has already told the government, through a self-attestation, that its safeguards are in place, an unmarked file that should have been protected is the gap between what got signed and what actually exists. We traced where that particular signature carries personal, statutory weight in Who Signs Your Self-Attestation, and What They Are Signing; the short version is that the affirming official is vouching for the accuracy of a description, and a marking failure is exactly the kind of thing that makes a description inaccurate without anyone intending fraud.

FIELD COPY
ISSUE Nº 031
CUI

32 CFR 2002

THE FEDERAL REGULATION DEFINING HOW CUI IS MARKED, SAFEGUARDED, AND DECONTROLLED

Does a CUI marking ever expire on its own?

No, and this is the piece of the lifecycle most programs never think about until an assessor asks. CUI does not sunset, age out, or lose its status because a program wrapped or a contract closed. Only the agency that designated it can decontrol it, and until that happens the material stays CUI, full retention and destruction obligations included. NIST 800-171's requirement 3.8.3 covers the specific case that trips people up most: destroying a hard drive, an old laptop, or a decommissioned server does not end your obligation unless the sanitization method actually meets the standard. A drive thrown in a dumpster because the program it supported is over is not decontrol. It is a media sanitization finding waiting to be discovered.

1

AGENCY THAT CAN DECONTROL A FILE - THE ONE THAT DESIGNATED IT, AND NO OTHER

What do we do when the contract just doesn't say?

Ask, in writing, and do not guess in either direction. This happens constantly - a package that is obviously covered arrives with no markings at all, or a DD Form 254 describes one thing while the statement of work describes another. The instinct to resolve the ambiguity yourself, by picking the reading that is easiest for your program, is the same instinct that produces both over-marking and under-marking. The correct move is a written question to the contracting officer, and it is worth understanding why that request matters beyond just getting the right answer: a documented question to a CO, with a documented reply on file, is itself evidence that your program treats CUI status as something to verify rather than assume. An assessor who finds that thread in your records is looking at a functioning program. An assessor who finds a guess is looking at a liability, whichever way the guess happened to land.

None of this replaces reading your specific contract, and none of it substitutes for the CUI Registry entry that actually governs the category on your program. What it should do is close the gap between "I think this is sensitive" and "I can point to the clause, the form, or the marking that makes it CUI" - which is the only question that has ever mattered. If you are not sure where your boundary actually sits, a readiness check is a faster way to find out than waiting for an assessor to tell you. ◆

3.8.3

THE NIST 800-171 REQUIREMENT GOVERNING MEDIA SANITIZATION WHEN CUI IS DESTROYED

◆ CUI BASIC VS. CUI SPECIFIED

The registry splits categories into two tracks. CUI Basic follows the uniform safeguarding rules in NIST 800-171. CUI Specified, export-controlled technical data among them, layers on whatever additional handling rule the underlying law adds. The marking on the material tells you which track applies - one more reason the marking, not your instinct, is the instruction.